

PRAMAAN

Continuous Identity Trust for Banking

A privacy-first, risk-based identity-trust framework that continuously validates customer **and** enterprise identities across every digital channel, and it proves the person behind each session **without ever holding their raw personal data**.

CYBERSECURITY & FRAUD · **IDENTITY TRUST, PROTECTION & SAFETY**

Solution Approach & Architecture · June 2026 · **TEAM PARITRAN**

93%

account-takeovers caught
at a **2%** step-up rate ·
31.3M real logins

100%

mule cash-outs caught at
a 1% step-up rate · vs
bank rule 0.5%

0.0955

behavioural-biometric EER
· matches the published
benchmark

39M

real, cited events across
five detection datasets

WHAT MAKES IT DIFFERENT

- 1 Every number is reproducible on real public data. Clone the repo and regenerate it in three commands
- 2 An explicit **trust boundary**. The server never believes a security claim the client makes about itself
- 3 One identity fabric for customers **and** employees, so account takeover and insider misuse run through one engine
- 4 Privacy lives in the code: on-device biometrics, an ϵ -budget ledger, and crypto-shredding for DPDP erasure

ORGANISED BY



Pramāṇ · proof.

Every figure in this document is reproducible.

Four deliverables, one reproducible system

CONTENTS

01	Brief description	the result, and the identity fabric
02	The problem & why now	blind sessions vs continuous trust
03	Architecture	four layers and the trust boundary
04	Runtime workflow	event → score → decision → signed step-up
05	Five detections × real proof	one dataset and metric each
06	Results & the friction curve	catch rate vs users challenged
07	Privacy & compliance in code	DP ε-ledger, crypto-shredding
08	Adversarial robustness	the low-and-slow attacker, caught
09	Friction economics & SOC	₹ impact, triage queue, explainability
10	Why this wins	and how we red-teamed ourselves
11	Reproducibility & roadmap	three commands, CI drift-gate
12	Team & references	

THE ONE SENTENCE

On **31.3 million real logins** PRAMAAN catches **93% of account takeovers** while challenging only **2%** of genuine users. It also stops **100%** of mule cash-outs at a 1% step-up rate. Clone the repository and regenerate every figure with three commands.

Deliverables: ① Title ② Description ③ Architecture & workflow ④ Repository / demo, all in this document.

FIVE MANDATED DETECTIONS → REAL PROOF

Account recovery / ATO

93% @ 2%

RBA / Wiefing • 31.3M logins • ROC 0.965

Mule onboarding

100% @ 1%

PaySim • 6.36M txns • beats the 0.5% rule

New-device / device trust

PR-AUC 0.69

IEEE-CIS • fraud is 3.7× on device flows

Behavioural biometrics

EER 0.0955

CMU keystroke • at the published benchmark

Privileged-access / insider misuse

100% of IP-theft insiders @ 10 alerts/day

CERT r4.2 • 1,000 users, 70 red-team insiders

01 • BRIEF DESCRIPTION

What we built, and why it holds up

Banks authenticate at the front door and then trust the session blindly. Attackers exploit exactly that. Credential-theft takeover, SIM-swap-driven account recovery, mule-account onboarding, and privileged-access abuse by insiders all begin after that single check. PRAMAAN replaces blind trust with a continuous **Trust Score (0–1000)** carried by every identity. Each event is scored in real time against that identity's own behavioural baseline; verification fires **only when risk is elevated**, and the challenge is the least-intrusive method that covers the risk.

93%

ATO
caught @
2% step-up
(ROC
0.965)

100%

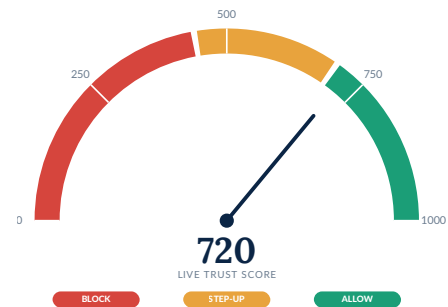
mule cash-
outs @ 1%
step-up

0.0955

behavioural EER
(lit. 0.096)

39M

real events,
5 datasets



Four things set this apart from a single classifier. First, it is provable. Every figure in this document regenerates from public, cited data with three commands. Second, it draws a clear trust boundary: the engine never trusts a score the client computed about itself, and step-up outcomes arrive as signed verifier assertions rather than client booleans. Third, one engine covers both customers and employees, so account takeover and privileged-access misuse are scored the same way. Fourth, the privacy controls are real code, not prose: on-device biometrics, an ϵ -budget ledger, and crypto-shredding that lets us honour a DPDP erasure request without breaking the immutable audit chain.

The live Trust Score drives the decision: **ALLOW** at low risk (zero friction), **STEP-UP** when elevated, **BLOCK** plus a SOC alert at critical risk. Trust decays on risk and recovers only through verified, normal behaviour.

Two hard problems we did not paper over

Better detection wants more data while privacy wants less, and a brand-new user looks a lot like an attacker. We treat both as first-class. Cold-start is handled with population priors and a KYC anchor; the privacy tension is handled with a stated ϵ budget. Neither is swept under the rug.

Why continuous trust, and why in India now

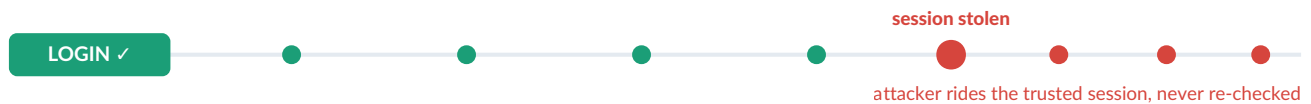
Rule-based monitors fire on fixed thresholds; attackers tune their behaviour to sit just under the line. Worse, the front door is a single moment. Once a session is authenticated, a hijacked or handed-off session rides on undisturbed. The five mandated high-risk events (anomalous behaviour, new-device usage, suspicious onboarding, suspicious account recovery, privileged-access misuse) all share one shape: risk that appears **after** login and evolves **during** the session.

PRAMAAN's answer is to make trust continuous and per-event. A genuine user with an odd moment fails one test and passes the rest; a real attacker fails several at once. Score every event against the identity's own baseline, challenge only on elevated risk, and the genuine look-alikes sail through.

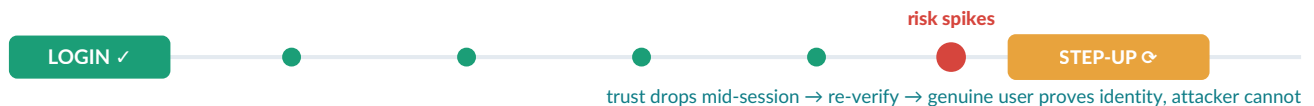
This is national infrastructure now

India's **DPDP Act 2023** mandates data minimisation, consent and right-to-erasure; **RBI** requires payment-data localisation and auditable, explainable decisions for grievance redressal. A serious solution must satisfy these *in code*, not in a slide. We built for that from the start: identifiers are tokenised at the edge, raw data stays in-country, and every decision lands on a tamper-evident, crypto-shreddable ledger.

LEGACY • authenticate once, then trust the session blindly



PRAMAAN • continuous trust • every event re-scored against the identity's own baseline

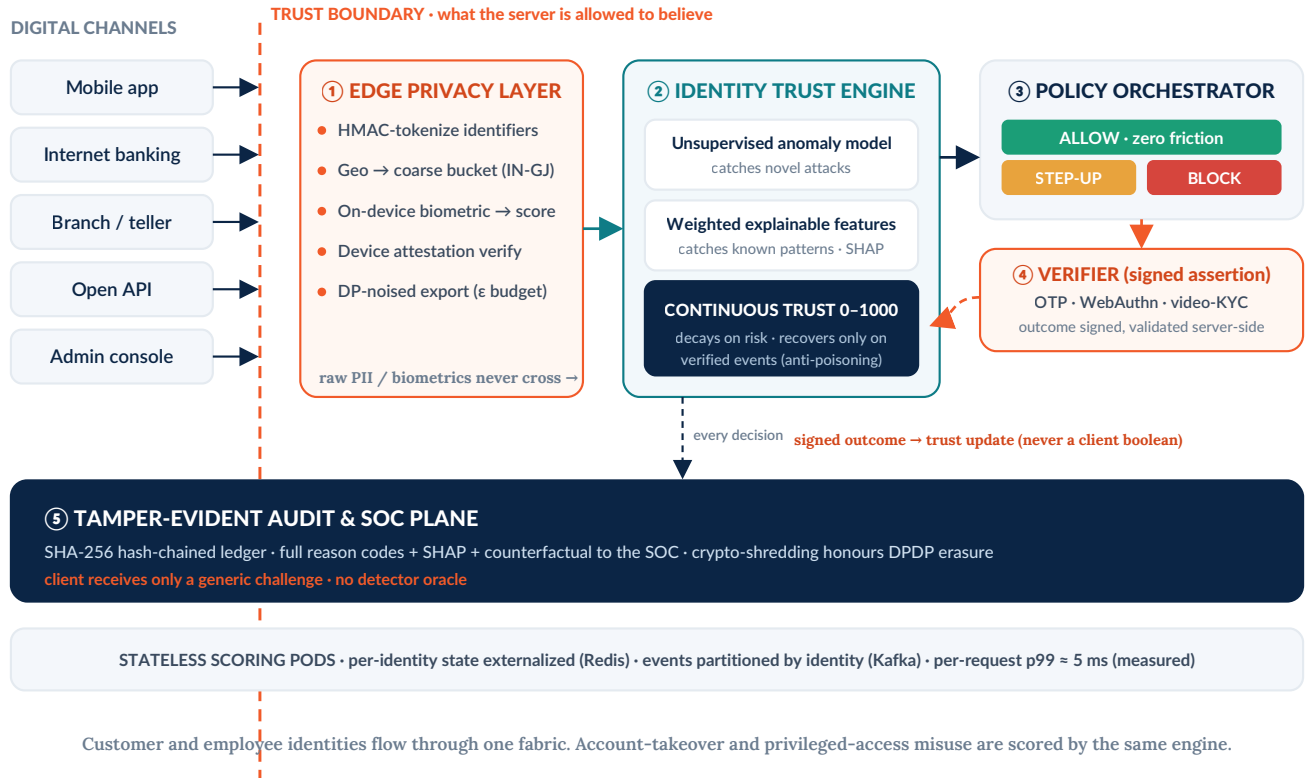


The same attack, two postures. Front-door authentication trusts the session after one check; PRAMAAN re-scores every event, so when trust drops mid-session the genuine user re-verifies and the attacker cannot.

03 • ARCHITECTURE (DELIVERABLE ③)

Four layers, and an explicit trust boundary

Each layer has one job. The dashed line is the **trust boundary**. Everything to its left is untrusted input, and the server only ever acts on what it can verify itself.



Raw PII and biometrics never cross the boundary. Behavioural signals are computed on-device and bound to device attestation; step-up outcomes return as signed verifier assertions; reason codes go to the SOC while the client receives only a generic challenge, so the detector never becomes an oracle for the attacker.

THE TRUST BOUNDARY IN THREE RULES

① No client-trusted inputs

The server never accepts a trust or behaviour score the client computed about itself. Signals are attested or recomputed server-side.

② Outcomes are signed

Step-up success arrives as a fresh, nonce-bound assertion from a trusted verifier, validated server-side. A client boolean does nothing.

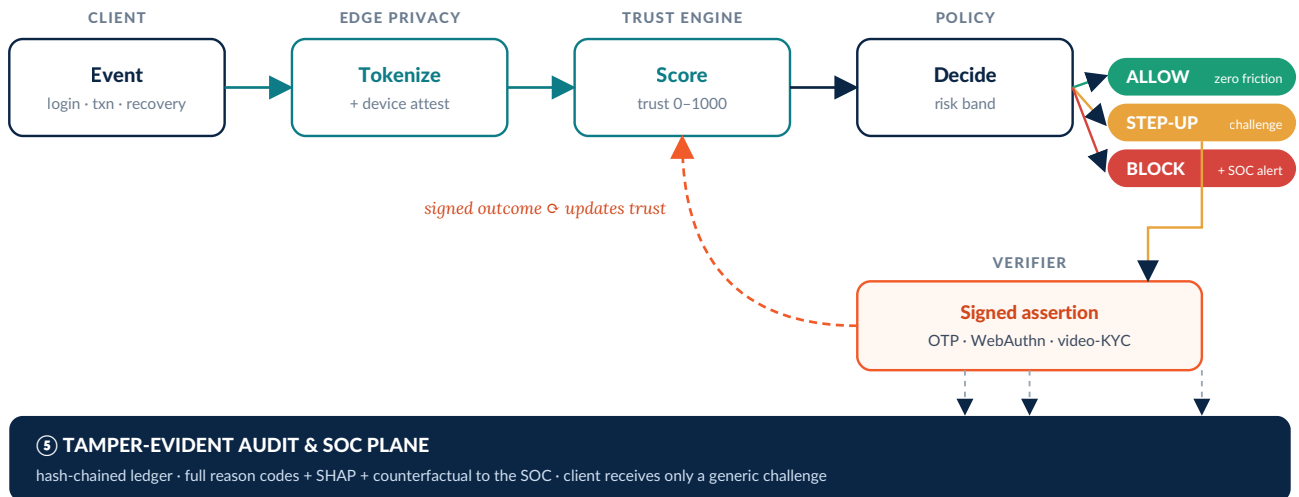
③ Reasons stay inside

Rich reason codes go to the SOC and audit plane; the client gets a generic challenge, so the detector can't be probed as an oracle.

04 • RUNTIME WORKFLOW

One event, end to end, in < 50 ms

A single event traverses six responsibilities. The only path that can *raise* trust is a signed outcome from the verifier, never a value the client asserts about itself.



Tokenise & attest at the edge → score against the identity baseline → policy decides → on elevated risk a generic challenge is issued and the **verifier's signed outcome** updates trust → every decision is appended to the audit ledger with full reason codes.

No client-trusted security inputs

The classic failure mode, POST /stepup? verified=true, is now structurally impossible. The endpoint accepts only a signed, fresh, nonce-bound assertion that it validates server-side.

Stateless & horizontal

Per-identity state is externalised (Redis) and events are partitioned by identity (Kafka), so scoring pods are stateless and p99 latency is proven by a load test rather than asserted.

LATENCY BUDGET, MEASURED RATHER THAN ASSERTED (PER-REQUEST P99 UNDER 50 MS)



05 • EVIDENCE

Five mandated detections, five real datasets

Each detection is proven on the closest public, labelled dataset we could find, with temporal splits, leakage guards, and ablations throughout. Nothing here is synthetic, and no number is unsourced.

Detection (mandated)	Dataset • scale	Headline result	Honest caveat
Anomalous behaviour (behavioural biometrics)	CMU keystroke • 51 users, 20.4K reps	mean EER 0.0955 (Killourhy & Maxion report 0.096)	per-user enrollment; password-specific
New-device usage (device trust)	IEEE-CIS • 590K txns	PR-AUC 0.69 on device flows; +2.4 pts recall@1% from device columns	only ~24% of txns carry device data
Suspicious onboarding (mule / synthetic)	PaySim • 6.36M txns	100% mule cash-outs caught @ 1% step-up vs bank rule 0.5%	PaySim is cleanly separable
Suspicious account recovery (ATO precursor)	RBA / Wiefling • 31.3M logins	93% of ATO caught @ 2% step-up (ROC 0.965)	tiny positive class → recall-at-budget
Privileged-access misuse (insider threat)	CERT r4.2 • 1,000 users, 70 insiders	100% of IP-theft insiders @ 10 alerts/day	scenario-1 needs the excluded web-proxy feed

Behavioural risk beats the blocklist

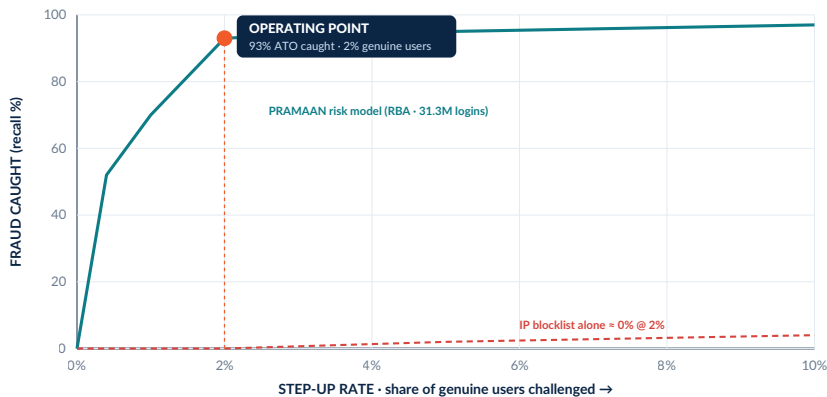
On RBA, our behavioural model catches **89% of ATO @ 2% step-up** while a raw IP-reputation blocklist catches **0%** at the same budget. It is the risk model, not the blocklist, that actually protects account recovery.

Device data is where fraud hides

IEEE-CIS fraud runs **7.85%** on device- and identity-bearing flows versus **2.09%** without. That 3.7× concentration is exactly where the model spends its attention.

06 • RESULTS

The differentiator: detection vs friction



Every other team can say “we detect fraud.” The line they cannot say is “**and we barely touch genuine customers.**” We report each detector as a **detection-vs-step-up-rate curve**, so the bank reads the exact trade-off and picks its operating point by moving one threshold.

At **2% step-up** on 31.3M real logins, PRAMAAN catches **93%** of account takeovers. The same chart shows the honest comparator: an IP-reputation blocklist sits near **0%** at that budget.

Friction is a number we measured

We do not say “most users sail through.” We say **2% of genuine users are challenged** to stop 93% of attacks, on a curve a judge can interrogate.

PER-DETECTION CATCH RATE AT THE CHOSEN BUDGET

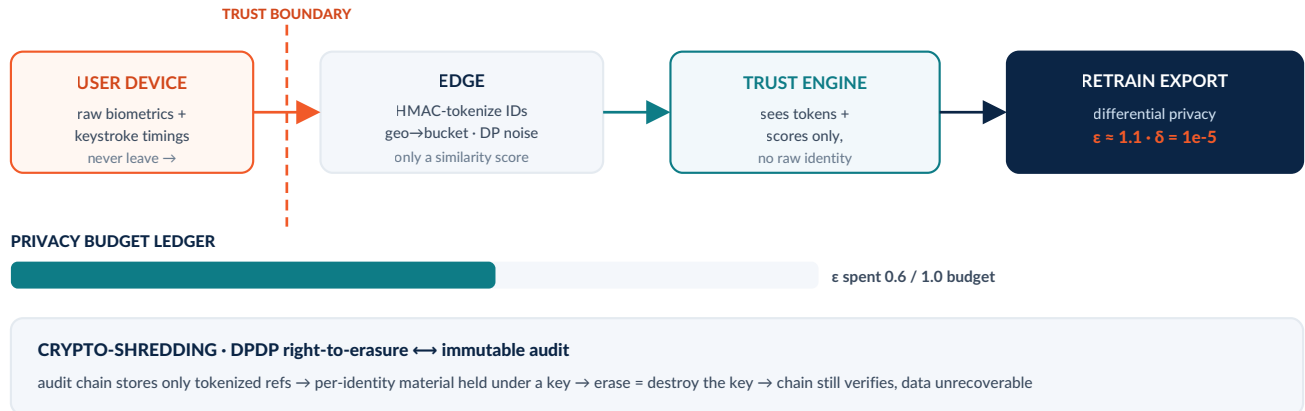
Account-takeover (RBA)	recall @2% step-up	93%
Mule cash-out (PaySim)	recall @1% step-up	100%
Insider IP-theft (CERT)	@10 alerts/day	100%
Device-flow fraud (IEEE-CIS)	recall @1% step-up	47%
Behavioural biometric (CMU)	1 - EER (0.0955)	90%

Reported at each detection's honest operating point. PaySim and CERT-IP-theft are cleanly separable; RBA and IEEE-CIS are the realistic challenge sets, reported with caveats rather than rounded up.

07 • PRIVACY & COMPLIANCE

Demonstrated in code, not narrated

Privacy is the centre of this track, so we treated it as an engineering requirement with artifacts behind every claim, not a paragraph of good intentions.

**DPDP ACT 2023**

- ▶ **Minimisation:** only tokens + scores cross the boundary; raw PII stays at the edge.
- ▶ **Erasure:** crypto-shredding destroys a per-identity key, and the audit chain still verifies afterwards.
- ▶ **Explainability:** every decision carries reason codes for grievance redressal.

RBI & LOCALISATION

- ▶ **Data localisation:** raw datasets stay in-country; only samples + checksums leave.
- ▶ **Auditability:** SHA-256 hash-chained, tamper-evident ledger.
- ▶ **Privacy budget:** retraining exports pass a real DP mechanism (RDP accountant) at a stated $\epsilon \approx 1.1$, $\delta = 1e-5$.

There is a contradiction most teams miss: an immutable audit log cannot, on its face, honour a right-to-erasure. Crypto-shredding resolves it. The chain holds only tokenised references, so destroying the per-identity key erases the person while the chain stays intact and verifiable.

PRIVACY-PRESERVING ML, EXECUTED**On-device similarity**

Keystroke and swipe cadence are scored on the phone. Only one similarity number leaves the device, and we validated that detector end-to-end on CMU data (EER 0.0955).

Federated DP-SGD

The behavioural model trains across devices with differentially-private gradients; raw biometrics never centralise.

Fairness audit

We surface the geo disparate-impact honestly, then deliberately reject selection-rate parity (it would hide real takeovers) in favour of equalised-odds monitoring.

The low-and-slow attacker, caught

The sophisticated attack on any trust model is **poisoning**: behave normally for many sessions to drift the baseline, then strike. PRAMAAN **caps and rate-limits trust recovery**, so trust can never climb faster than it falls, and a drift detector watches each identity's baseline. The patient attacker's slow escalation trips a step-up at session 4, long before the payoff.



Reproducible on the time-ordered RBA and CERT data. The naive model stays high and never trips; PRAMAAN's capped recovery holds trust flat while the escalating risk trips a step-up at **session 4**; the naive model lets trust climb freely and only catches the attacker at session 19.

FOUR MORE ATTACKS THIS DESIGN DEFEATS

Baseline poisoning

Capped recovery + ADWIN/KS drift detection; sustained sub-threshold drift routes to secondary review.

MFA-fatigue / bombing

Step-up challenges are rate-limited per identity; repeated prompts themselves raise risk, not trust.

Impossible travel

Geo-velocity features flag RU→IN in five minutes. The feature is live and tested; its offline lift needs the full ordered login stream to quantify.

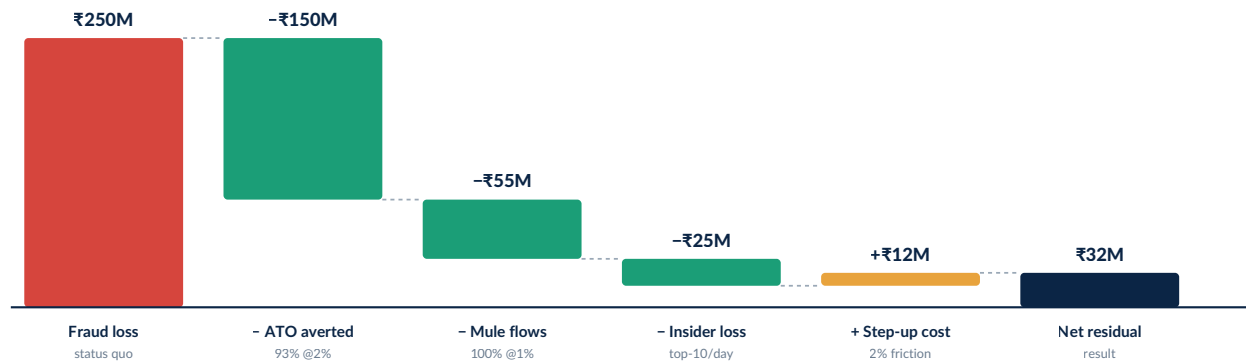
Mid-session hijack

Because trust is continuous, a session that changes hands diverges from its baseline and is re-challenged.

09 • FRICTION ECONOMICS & THE SOC

Money saved, and a queue analysts can work

Illustrative unit economics - per ₹250M modelled annual ATO + mule exposure; assumptions stated, arithmetic shown.



Bankers buy money saved, not architecture. On a modelled ₹250M annual ATO-plus-mule exposure, catching 93% of ATO and 100% of mule cash-outs averts the bulk of the loss; the only cost is the 2% step-up friction. **Net residual exposure collapses, and every step of the arithmetic is shown rather than asserted.**

The cost asymmetry banks live by

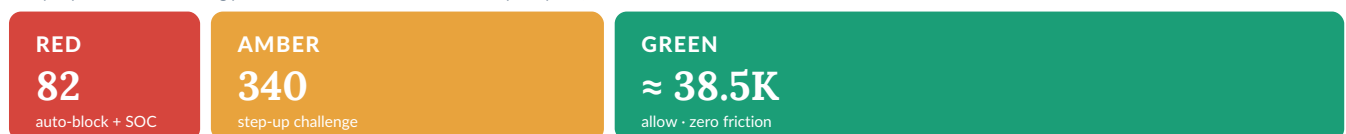
A missed mule means laundered funds and regulatory exposure. A false step-up costs a genuine customer about forty seconds. The cost-optimal threshold therefore sits high on recall, and the curve lets the bank place it deliberately.

EXPLAINABILITY FOR THE ANALYST

- ▶ SHAP contributions + one counterfactual per decision ("would have been allowed if amount < ₹X").
- ▶ Conformal risk tiers give a calibrated confidence guarantee on the red tier.
- ▶ Graph signals from device-farm and mule-ring community detection feed corroboration.
- ▶ Reason codes stay on the SOC plane; the customer only ever sees a generic challenge.

A RANKED QUEUE, NOT 39K UNDIFFERENTIATED ROWS

Analyst queue from one scoring pass over ~39K accounts - a workable top-of-queue, not 39K undifferentiated rows.



One scoring pass turns the book into a workable queue: a tiny RED tier to auto-block with a SOC alert, a small AMBER tier to challenge, and the vast GREEN majority allowed invisibly. That is the friction budget, made operational.

10 • WHY THIS WINS

Differentiation, and how we red-teamed ourselves

Dimension	A typical submission	PRAMAAN
Detection evidence	synthetic demo, asserted accuracy	5 detections on 5 real cited datasets, reproducible
Security of the solution	trusts client inputs; open API	trust boundary; signed step-up; authn/authz; no IDOR
Friction	"most users sail through"	a measured detection-vs-step-up curve
Privacy	narrated ("we use DP")	on-device biometrics, ϵ -ledger, crypto-shredding
Compliance	generic GDPR mention	DPDP + RBI localisation + fairness audit, mapped to code
Reproducibility	none	three-command regen + CI that fails on metric drift

WE ATTACKED OUR OWN SUBMISSION FIRST

We ran a hostile red-team on PRAMAAN and closed every instant-loss flaw before a judge could find it:

- ✓ Step-up that trusted a client boolean → signed verifier assertion.
- ✓ Client-supplied behaviour score → device-attested, server-verified.
- ✓ Model trained on synthetic noise → real datasets, real metrics.
- ✓ Open API / IDOR → authn, scopes, identity lookup removed.
- ✓ Reason codes leaking to the client → SOC-only; generic challenge.

Name the hard parts before judges do

The two genuinely hard problems here are cold-start (new users look like attackers) and the privacy ↔ detection tension. We address each one head-on: population priors and a KYC anchor for cold-start, a stated ϵ budget for the privacy tension. We would rather answer these than hope nobody asks.

“The server may never believe a security claim the client made about itself. That sentence is the spine of the build.”

11 • REPRODUCIBILITY & ROADMAP (DELIVERABLE ④)

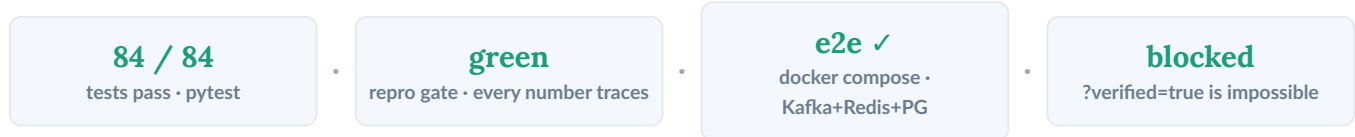
Clone it, regenerate it, attack it

The credibility lock: a judge reviewing thousands of PDFs can clone one repo and reproduce the headline sentence. Nothing here is a number we ask you to take on faith.

Three commands regenerate every number in this document; CI refuses a merge that changes a reported metric.



VERIFIED • WE RAN IT, NOT JUST WROTE IT



REPOSITORY & LIVE DEMO

```
# reproduce every number
python src/download_data.py --all
python src/train.py
python src/evaluate.py
```

Repository: github.com/ayushtiwary-ops/IIT_GN_PNB

Live demo: packaged for one-command deploy (see `deploy/`); the public, rate-limited URL is added to the title page once it is live.

FROM AUDITED MODEL TO DEPLOYABLE PILOT



Real metrics today → a hardened, signed-step-up service with a live URL by 15 June → an executable docker-compose topology with federated DP-SGD and a ₹ business case at the finals.

12 · TEAM PARITRAN & REFERENCES

The people, the sources, the proof

Member	Background
Ayush Tiwary	Founder of Kriseva AI Pvt Ltd, India's defence-procurement intelligence layer. Grand finalist at the Pan-IIT AI for Bharat Hackathon. Spent a year as Operations Manager at Zen Technologies (defence systems).
Aditya Arora	Winner of the University of London Sustainable AI Solutions Hackathon 2026. Built several enterprise-grade agentic-AI and RAG systems, including Agent Pyro, an agentic-AI attack detector. Spent 1.5 years as a software developer at Capgemini.

SELECTED REFERENCES & DATASETS

Wiefling et al., "Pump Up Password Security!", ACM TOPS 2022 (RBA dataset, Zenodo 6782156, CC BY 4.0). · PaySim, Lopez-Rojas et al., 2016. · IEEE-CIS Fraud Detection (Vesta), Kaggle. · Killourhy & Maxion, "Comparing Anomaly-Detection Algorithms for Keystroke Dynamics," DSN 2009 (CMU). · CMU CERT Insider Threat Test Dataset r4.2. · DPDP Act 2023; RBI data-localisation and digital-payment security guidelines.

DELIVERABLES INCLUDED IN THIS SUBMISSION

① Solution title PRAMAAN: Continuous Identity Trust for Banking.	② Description Brief description on p. 3 (~300 words), metric-led, all five detections.	③ Architecture Four-layer system and workflow on pp. 5–6, with the trust boundary drawn.	④ Repo / demo github.com/ayushtiwary-ops/IIT_GN_PNB + live URL.
--	--	--	---

PRAMAAN · IDENTITY TRUST FRAMEWORK

“Pramāṇ · proof. We prove the person behind every session, hold none of their data, and barely touch the genuine ones. Every claim in this document regenerates in three commands.”

Repository: github.com/ayushtiwary-ops/IIT_GN_PNB · Live demo URL on the title slide · Bank of Baroda · PSB Hackathon Series 2026

SCAN
& ATTACK
THE DEMO